Informe de incidente de seguridad

África Stausten

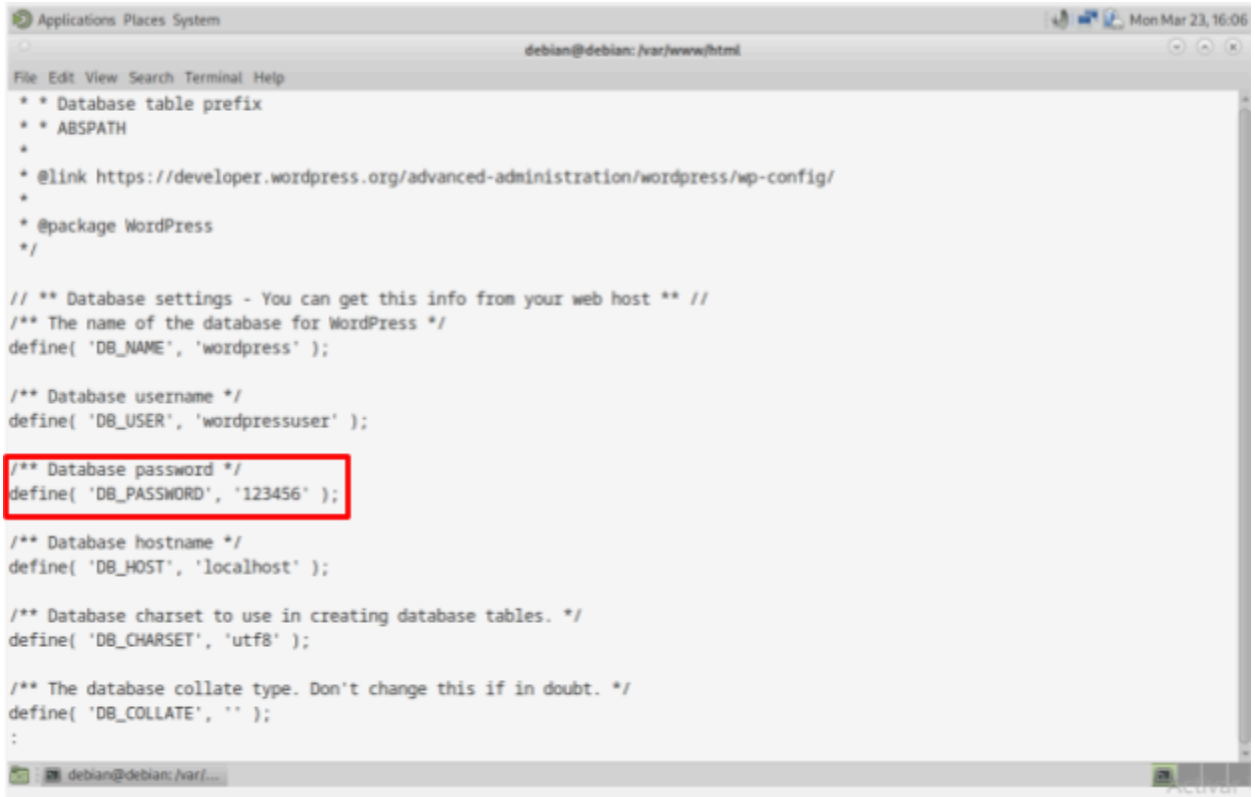
84geeks8@

4geeks Academy Proyecto Final
Marzo 2026

Introducción

El día 8 de octubre de 2024 se detectó una intrusión (no autorizada) al servidor web WordPress; alteración de archivos y permisos no identificados. En este informe se busca detallar la búsqueda del compromiso, analizar los archivos comprometidos y tomar las respectivas medidas con el objetivo de garantizar la seguridad y erradicar vulnerabilidades.

Análisis forense



- Esta captura de pantalla sugiere desde el archivo wp-config.php que existe una posible vulnerabilidad al estar en uso una contraseña débil (123456) para el usuario root, lo que podría dar paso a accesos no autorizados.

Dado el caso, el posible origen de los accesos no autorizados registrados el 8 de octubre podría deberse a esto.

```
debian@debian:/$ sudo journalctl | grep "Accepted"
Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134 port 45623 ssh2
Mar 23 16:29:08 debian sshd[2847]: Accepted password for debian from 192.168.1.146 port 60479 ssh2
Mar 23 16:29:08 debian sshd[2849]: Accepted password for debian from 192.168.1.146 port 60480 ssh2
Mar 24 21:22:48 debian sudo[31291]:   debian : TTY=pts/0 ; PWD=/ ; USER=root ; COMMAND=/usr/bin/grep Accepted
```

Utilizando journalctl se averigua la IP de origen (192.168.0.134) y el puerto SSH 22.

```
debian@debian:/var/log$ sudo cat /root/.bash_history | tail -n 50
sudo visudo
sudo systemctl stop speech-dispatcher
sudo systemctl disable speech-dispatcher
systemctl list-units --type=service
```

El atacante en concreto quiso modificar permisos utilizando sudo visudo.

```
/usr/bin/watch                                    [ OK ]
/usr/bin/wc                                       [ OK ]
/usr/bin/wget                                     [ OK ]
/usr/bin/whatis                                   [ OK ]
/usr/bin/whereis                                  [ OK ]
/usr/bin/which                                    [ OK ]
/usr/bin/who                                      [ OK ]
/usr/bin/whoami                                   [ OK ]
/usr/bin/numfmt                                   [ OK ]
/usr/bin/kmod                                     [ OK ]
/usr/bin/systemd                                  [ OK ]
/usr/bin/systemctl                                [ OK ]
/usr/bin/gawk                                     [ OK ]
/usr/bin/lwp-request                              [ Warning ]
/usr/bin/bsd-mailx                                [ OK ]
/usr/bin/dash                                     [ OK ]
/usr/bin/x86_64-linux-gnu-size                    [ OK ]
/usr/bin/x86_64-linux-gnu-strings                 [ OK ]
/usr/bin/inetutils-telnet                         [ OK ]
/usr/bin/which.debianutils                        [ OK ]
/usr/lib/systemd/systemd                          [ OK ]
```

Haciendo un escaneo básico del servidor en busca de malwares utilizando chkrootkit se detectó actividad sospechosa en el directorio /usr/bin/lwp-request. No se han observado modificaciones recientes al revisar el archivo por lo que se trata de un falso positivo.

Medidas correctivas

```
Applications Places System                                   Tue Mar 24, 21:47
debian@debian: /var/log
File Edit View Search Terminal Help
  GNU nano 7.2                          /etc/ssh/sshd_config *
# Authentication:

#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile     .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no

^G Help      ^O Write Out  ^W Where Is   ^K Cut       ^T Execute    ^C Location   M-U Undo      M-A Set Mark
^X Exit      ^R Read File  ^\ Replace    ^U Paste     ^J Justify    ^/ Go To Line M-E Redo      M-6 Copy
debian@debian: /var/l...
```

Modificamos el archivo /etc/ssh/sshd_config; antes de la modificación la directiva PermitRootLogin se encontraba activa indicando un fallo crítico en la seguridad del servidor ya que facilita la toma de control del superusuario al atacante. Desactivamos esta opción cambiándolo a PermitRootLogin no.

```
debian@debian:/var/log$ sudo passwd root
New password:
Retype new password:
passwd: password updated successfully
```

Se realiza un cambio de contraseña del superusuario endureciendo así la seguridad base del servidor. 123456 —> 84geeks8@

Seguidamente, comprobamos que no se hayan creado backdoors revisando la lista de usuarios en /etc/passwd y /etc/sudoers:

```
debian@debian:/var/log$ grep ':0:' /etc/passwd
root:x:0:0:root:/root:/bin/bash
```

Recomendaciones preventivas

1. Prevenir accesos indebidos revisando periódicamente la lista de usuarios en /etc/passwd y /etc/sudoers.
2. Aplicar el principio de mínimo privilegio.
3. Implementar un sistema de monitorización a tiempo real para detectar actividad sospechosa.